

Rapport de TP — Cloud & Virtualisation

Exploration, Administration & Sécurisation VMware ESXi vs Proxmox VE

Réalisé par : Hamza Khchichine

Année universitaire : 2025 - 2026

1. Réponses aux questions de réflexion (Concepts d'Architecture)

1. Pourquoi un hyperviseur de Type 1 est-il préféré en production par rapport au Type 2 ?

Un hyperviseur de Type 1 (bare-metal) s'installe directement sur le matériel de la machine, sans nécessiter de système d'exploitation hôte. En production, il est préféré pour deux raisons majeures :

- **Performances** : L'absence d'OS hôte élimine une surcouche logicielle gourmande en ressources, permettant à l'hyperviseur de gérer directement et plus efficacement le CPU, la RAM et les accès disques.
- **Sécurité et Isolation** : La surface d'attaque est grandement réduite. Contrairement au Type 2, l'hyperviseur ne subit pas les vulnérabilités d'un système d'exploitation sous-jacent (Windows, macOS), garantissant une isolation beaucoup plus forte entre les environnements virtuels.

2. Quel est le risque d'accumuler des snapshots sans les consolider ?

Un snapshot n'est pas une sauvegarde, mais une capture d'état qui crée des fichiers "delta" empilés pour chaque nouvelle modification virtuelle. Accumuler ces snapshots entraîne trois risques critiques :

- **Chute de performances** : À chaque lecture, le système doit traverser toute la chaîne des fichiers "delta" pour reconstituer l'information.
- **Saturation de l'espace de stockage** : Ces fichiers grossissent avec l'activité de la VM et peuvent rapidement remplir un Datastore.
- **Risque élevé de corruption** : Si un seul fichier de la chaîne de snapshots est endommagé, l'intégralité des données postérieures est perdue, rendant potentiellement la machine virtuelle inutilisable.

3. Pourquoi est-il important de segmenter le réseau de management de celui des VMs ?

La segmentation réseau est un principe protecteur fondamental. Le réseau de management donne accès à l'administration de l'hyperviseur (interfaces web, SSH). Si ce réseau est partagé avec celui des machines virtuelles hébergées, une machine virtuelle compromise pourrait servir de point de pivot à un attaquant pour cibler directement l'hyperviseur physique (par sniffing de mot de passe, force brute, ou exploitation de faille). Les séparer bloque cette menace d'escalade des privilèges et d'accès non autorisé.

2. Réponses aux questions de réflexion (Cybersécurité VMware ESXi)

1. Un attaquant obtient l'accès SSH à votre ESXi. Quels sont les risques ? Quelles mesures auraient pu l'en empêcher ?

Risques : L'attaquant dispose des privilèges administratifs racine. Il peut supprimer ou chiffrer toutes les VMs stockées (comme les ransomwares spécifiques ESXiArgs), voler des disques entiers (fuite de données) ou implanter des portes dérobées persistantes dans l'infrastructure de virtualisation.

Mesures préventives :

- Veiller à ce que le service SSH (TSM-SSH) reste désactivé, et ne l'allumer qu'en cas de stricte maintenance.
- Mettre en place un timeout d'inactivité du Shell (ex: UserVars.ESXiShellTimeOut = 600).
- Protéger l'accès port 22 par le pare-feu intégré d'ESXi (restreindre l'adresse IP source) et privilégier l'authentification par création de comptes restrictifs plutôt que l'accès root par mot de passe.

2. Pourquoi est-il dangereux de laisser le mode "promiscuous" activé sur un port group ?

En temps normal, une interface réseau virtuelle (VM) ne reçoit que les trames qui s'adressent à elle. Le mode "promiscuous" autorise une interface à écouter tout le trafic transitant sur le même Port Group ou vSwitch. Si un attaquant pirate l'une des VMs sous ce commutateur virtuel, il pourrait utiliser des outils d'écoute réseau (sniffing, Wireshark, tcpdump) pour intercepter le trafic de toutes les autres VMs clientes, exposant ainsi des données sensibles (mots de passe en clair, architecture, requêtes d'API).

3. Comment un SIEM peut-il exploiter les logs ESXi pour détecter une compromission ?

En configurant ESXi pour envoyer ses logs vers un serveur syslog distant (captés par le SIEM), l'équipe SOC peut centraliser et corréler des événements en temps réel. Le SIEM sera capable de lever des alertes sur des comportements anormaux, tels que :

- Des tentatives répétées d'authentification échouées (bruteforce visible dans `auth.log`).
- L'activation inattendue du service SSH, la création d'un utilisateur non autorisé, ou la suppression répétée de VMs effectuées à une heure inhabituelle (`hostd.log` et `vobd.log`).

4. Quel est l'intérêt de créer des comptes nominatifs plutôt que de partager le mot de passe root ?

Cela répond à deux principes clés de la sécurité des systèmes d'informations :

- **L'imputabilité :** En auditant les logs, il est possible d'identifier exactement "qui" a exécuté "quelle commande". Ce qui est impossible si toute l'équipe informatique utilise un compte partagé "root".
- **Le moindre privilège :** Les administrateurs peuvent affecter des rôles granulaires à chaque compte (ex: Read-Only pour un auditeur) plutôt que d'accorder automatiquement à tous les droits destructifs totaux sur l'infrastructure.

De plus, en cas de départ d'un collaborateur, son compte peut être immédiatement révoqué sans avoir besoin de changer les mots de passe de tous les autres personnels.

3. Analyses et Captures d'écran des configurations

3.1. Architecture du commutateur virtuel : vSwitch0

Cette première capture d'écran permet de visualiser la configuration intégrale du réseau par défaut sur VMware ESXi (vSwitch0). On y constate qu'une ségrégation fonctionnelle des réseaux est en place, distribuée dans les topologies des "Port groups" :

- **Management Network** : il s'agit du port de l'hyperviseur pour son administration (port VMkernel configuré avec l'IP 192.168.114.130).
- **VM Network** : le pool de connexion attribué par défaut aux machines virtuelles créées en production, comprenant nos deux VMs de test (Hamza_hh et kk).

Le tout redirige le trafic vers la couche physique vers l'adaptateur parent unique (vmnic0).

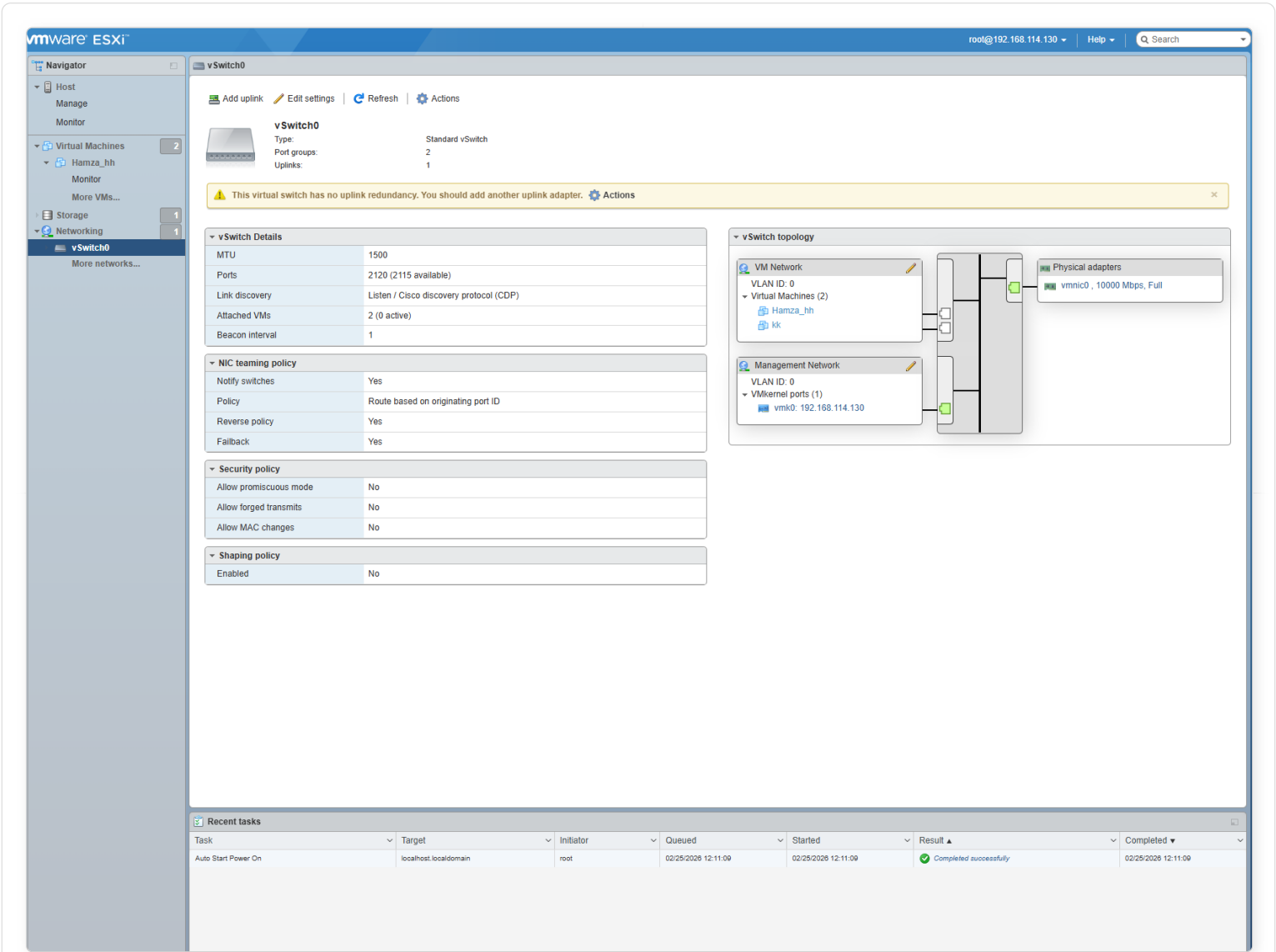


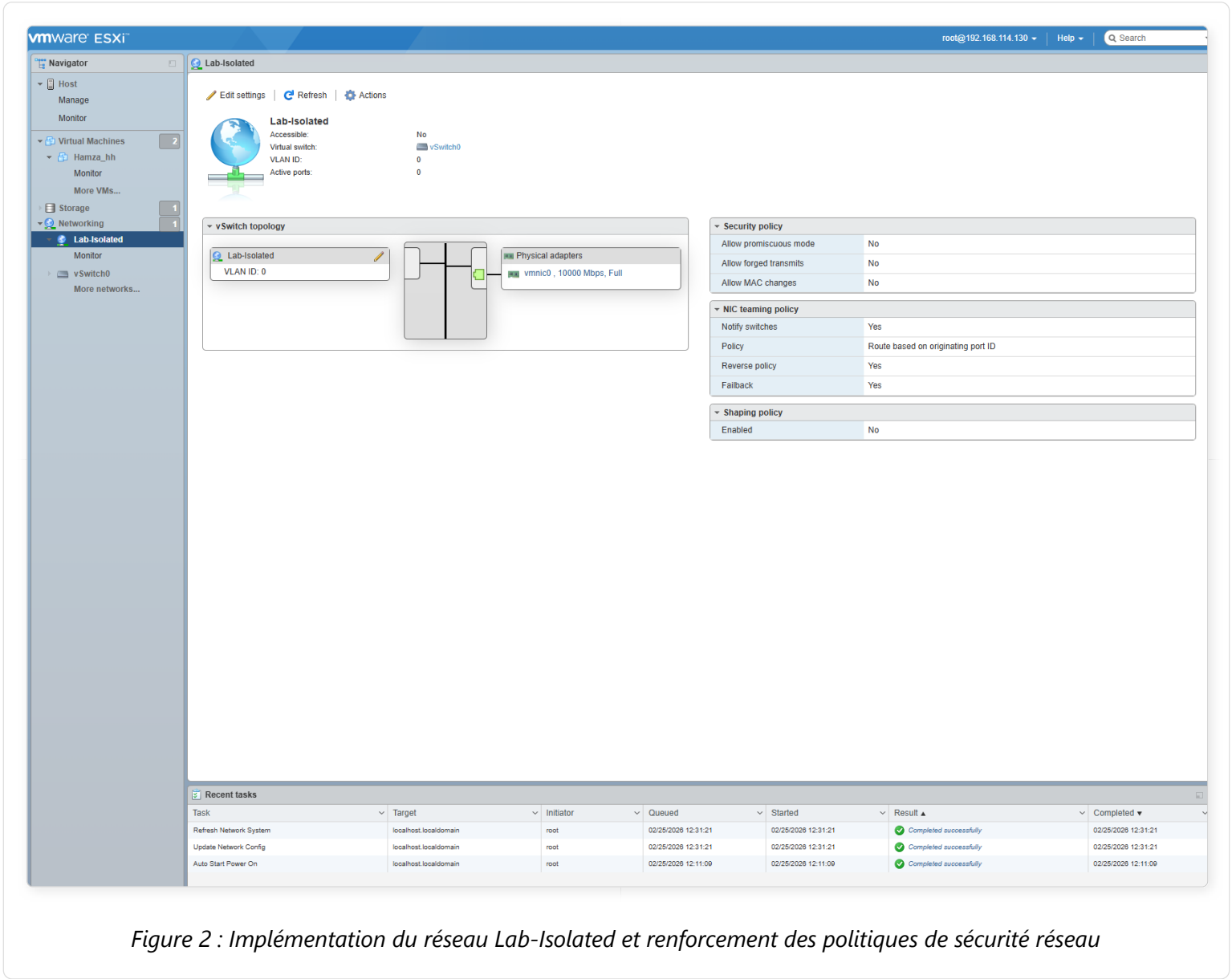
Figure 1 : Topologie et configuration système du commutateur vSwitch0 avec les VMs attachées

3.2. Réseau isolé et Stratégies de Sécurité appliquées

La deuxième capture démontre l'implémentation d'un groupe de port spécifique : Lab-Isolated. Conformément à la méthodologie du TP, l'isolation est garantie en lui attribuant le VLAN ID 0 séparément (bien qu'il dépende du

vSwitch0 parent). L'analyse de la section "Security Policy" démontre concrètement la bonne implémentation des règles de protection requises pour de l'hébergement réseau. Toutes les options sont définies sur **No (Reject)** :

- **Allow promiscuous mode : No** (Protège le réseau contre le Sniffing de trames entre VMs sur la couche 2).
- **Allow MAC changes : No** (Empêche une machine virtuelle d'usurper l'adresse d'une autre machine voisine).
- **Allow forged transmits : No** (Interdit l'usurpation d'identifiant depuis le système invité envers des paquets sortants altérés).



3.3. Renforcement et vérification des Services Système (Hardening)

Enfin, pour clôturer l'intégration des règles de cybersécurité, un audit du panel de gestion des services locaux permet de valider le processus de Hardening de l'hyperviseur ESXi. Ici, la sélection de la ligne `TSM-SSH` (SSH) confirme son statut gris et désactivé : **Stopped** (Arrêté). Seuls les services requis comme la console locale (`DCUI`) et le syslogging (`vm syslogd`) demeurent en **Running**. L'inactivation du protocole SSH réduit immensément la surface d'attaque et bloque d'éventuelles attaques par force brute à distance qui viseraient l'accréditation Root.

localhost.localdomain - Manage

SystemHardwareLicensingPackagesServicesSecurity & users

StartStopRestartRefreshActions

Q Search

Name ▲	Description ▼	Status ▼	Source ▼	Firewall rules ▼
atftstd	atftstd	Stopped	Base system	None
DCUI	Direct Console UI	Running	Base system	None
dpd	dpd	Stopped	vmware-dp	None
kmxd	kmxd	Stopped	Base system	None
lbtid	Load-Based Teaming Daemon	Running	Base system	None
lwsmid	Active Directory Service	Stopped	Base system	None
ntpd	NTP Daemon	Stopped	Base system	ntpClient
pcscd	PC/SC Smart Card Daemon	Stopped	Base system	None
ptpd	PTP Daemon	Stopped	Base system	ptpd
sfcbid-watchdog	CIM Server	Stopped	Base system	CIMHttpServer, CIMHttpsServer
slpd	slpd	Stopped	Base system	CIMSLP
snmpd	SNMP Server	Stopped	Base system	snmp
TSM	ESXi Shell	Stopped	Base system	None
TSM-SSH	SSH	Stopped	Base system	None
vitd	vitd	Stopped	vmware-dp-vit	vitd
vmsyslogd	Syslog Server	Running	Base system	None
vpxa	VMware vCenter Agent	Running	Base system	vpHeartbeats
xorg	X.Org Server	Stopped	esx-xserver	None

18 items



SSH

Name
Status

TSM-SSH
Stopped

Figure 3 : Vérification de l'arrêt du service SSH dans l'interface Host Client

4. Réponses aux questions de réflexion (Cybersécurité Proxmox VE)

1. Quels avantages offre le RBAC de Proxmox par rapport à la gestion des comptes ESXi standalone ?

Le RBAC (Role-Based Access Control) de Proxmox est beaucoup plus granulaire et natif que celui d'ESXi standalone. Il gère les utilisateurs, groupes, rôles complets et les permissions par chemins (paths), ce qui permet de donner l'accès spécifiquement à une seule machine virtuelle ou ressource isolée. ESXi standalone dispose de rôles basiques et figés (Admin, Read-Only, No Access) et nécessite un vCenter payant pour obtenir une gestion riche similaire.

2. Pourquoi un conteneur LXC offre-t-il une isolation moindre qu'une VM ? Quel risque en cybersécurité ?

Un conteneur LXC partage le même noyau Linux que l'hôte (Proxmox), par le biais des namespaces et cgroups, contrairement à une machine virtuelle qui exécute son propre noyau invité. Le risque majeur en cybersécurité est l'évasion de conteneur (container escape) : si une vulnérabilité critique du noyau partagé est exploitée depuis un conteneur, l'attaquant peut potentiellement compromettre le nœud Proxmox physique en entier.

3. Pourquoi est-il critique de séparer le stockage des sauvegardes du stockage des VMs ?

Séparer physiquement ou logiquement le stockage garantit que si le stockage principal exécutant les VMs (ex: datastore local) subit une corruption, une panne matérielle critique ou une attaque (ex: ransomware), les sauvegardes n'en seront pas affectées. Les sauvegardes doivent être isolées et stockées hors site (ex: sur un serveur NFS ou NAS externe indépendant) pour permettre une réelle résilience et un plan de reprise d'activité (PRA).

4. Comment un attaquant pourrait-il exploiter une interface Proxmox exposée sur Internet ? Quelles protections mettre en place ?

Une interface exposée (généralement sur le port TCP 8006 ou SSH 22) peut subir des attaques de force brute sur ses mécanismes d'authentification, l'exploitation de failles zero-day, ou l'interception et réutilisation de sessions. Étant un système Linux Debian complet, la compromission est critique. Protections obligatoires : bloquer l'interface sur l'Internet public via pare-feu (whitelisting IP restreint), exiger l'utilisation d'un VPN pour l'accès administratif, activer le pare-feu intégré de Proxmox Datacenter, et obliger l'Authentification Multi-Facteurs (2FA).

5. Réponses aux questions de réflexion (Comparaison ESXi vs Proxmox VE)

1. Si vous deviez déployer un lab de forensic, laquelle des deux plateformes choisiriez-vous ? Justifiez.

Je choisirais **Proxmox VE**. Il excelle face aux exigences d'un labo forensique grâce à ses fonctionnalités natives et gratuites : une immense flexibilité réseau (création illimitée de bridges isolés sans interfaces physiques pour éviter les fuites de malwares), des snapshots rapides sur LVM-thin / qcow2 permettant de réinitialiser instantanément des machines infectées, et la puissance de ses conteneurs LXC pour orchestrer des boîtes à outils d'analyse rapidement. Il intègre aussi par nature les outils Linux facilitant ainsi les captures de paquets réseau.

2. Quels sont les risques spécifiques liés au fait que Proxmox est un Debian complet ?

Un système Linux Debian complet offre une surface d'attaque intrinsèquement et significativement plus large qu'un hyperviseur "bare-metal" hyper spécialisé (comme VMkernel sur ESXi). Proxmox contient par défaut de très nombreux paquets, daemons (ex: SSH, apt, systemd), et services qui peuvent être sujets à des vulnérabilités, ou être mal configurés. Cela requiert donc une application des correctifs (patching) scrupuleuse et une politique de durcissement (hardening) active.

3. Pourquoi le Broadcom (anciennement VMware) vient-il de modifier ses licences ? Quel impact pour les PME ?

Suite au rachat de VMware par Broadcom, l'éditeur a rationalisé son offre commerciale en mettant fin aux licences perpétuelles traditionnelles au profit de modèles par abonnement (subscriptions groupés). Pour la très grande majorité des PME, cela se caractérise par une augmentation colossale des coûts IT d'infrastructure, certaines licences abordables disparaissant. Cet impact contraint de nombreuses PME à opérer des migrations défensives vers Proxmox VE, solution souveraine et libre.

6. Captures d'écran Proxmox VE (Interface et Configurations)

Cette section démontre l'utilisation de la plateforme de virtualisation Proxmox VE, affichant l'interface graphique de gestion réseau et système selon le contexte du document.

